

Unit I

Introduction to Malware and Malware Analysis

Dr. Manu V.T.

Assistant Professor (Cyber Security & Digital Forensics), NFSU Bhopal

Introduction

- Malware definition
- Malware Types
- Malware analysis
- Forensic importance of malware analysis
- Introduction to different analysis techniques
- Malware behavior
- Setting up malware analysis laboratory

Malware definition

- Malware is a code that performs malicious actions; it can take the form of an executable, script, code, or any other software.
- Attackers use malware to steal sensitive information, spy on the infected system, or take control of the system.
- It typically gets into your system without your consent and can be delivered via various communication channels such as email, web, or USB drives.

Malware Types

- **Viruses:**

- Designed to infiltrate and multiply within host files, transitioning from one system to another.
- They latch onto credible programs, springing into action when the infected files are triggered.
- Their destructive powers can range from corrupting or altering data to disrupting system functions, and even spreading through networks, inflicting widespread havoc.

- **Worms:**

- Autonomous malware capable of multiplying across networks without needing human intervention.
- They exploit network weaknesses to infiltrate systems without permission.
- Once inside, they can either deliver damaging payloads or keep multiplying to other vulnerable devices. Worms can initiate swift and escalating infections, resulting in enormous disruption and even potential denial of service attacks.

- **Trojan:**

- Disguises itself as a regular program to trick users to install it on their systems.
- Once installed, it can perform malicious actions such as stealing sensitive data, uploading files to the attacker's server, or monitoring webcams.

- **Backdoor / Remote Access Trojan (RAT):**

- A type of Trojan that enables the attacker to gain access to and execute commands on the compromised system.
- Attackers can leverage them to retain prolonged control, extract data, or instigate additional attacks.

Malware Types

- **Adware:**

- Presents unwanted advertisements (ads) to the user.
- Gets delivered via free downloads and can forcibly install software on your system.

- **Botnet:**

- Group of computers infected with the same malware (called bots), waiting to receive instructions from the command-and-control server controlled by the attacker.
- The attacker can then issue a command to these bots, which can perform malicious activities such as DDOS attacks or sending spam emails.

Malware Types

- **Ransomware:**

- Malware that holds the system for ransom by locking users out of their computer or by encrypting their files.
- Attackers then demand a ransom in return for the decryption key, effectively holding the victim's data to ransom.
- The impacts of ransomware attacks can debilitate organizations and individuals alike, leading to severe financial and reputational harm.

- **Rootkit:**

- Malware that provides the attacker with privileged access to the infected system and conceals its presence or the presence of other software.
- These are stealthy forms of malware designed to gain unauthorized access and control over the fundamental components (the "root") of an operating system.
- They alter system functions to conceal their presence, making them extremely challenging to spot and eliminate.
- Attackers can utilize rootkits to maintain prolonged access and dodge security protocols.

Malware Types

- **Spyware:**

- Stealthily gathers sensitive data and user activities without their consent.
- It can track online browsing habits, record keystrokes, and capture login credentials, posing a severe risk to privacy and security.
- The pilfered data is often sent to remote servers for harmful purposes.

- **Droppers:**

- Malware used to transport and install extra malicious payloads onto infected systems.
- They serve as a conduit for other malware, ensuring the covert installation and execution of more sophisticated threats.

Malware Classification based on Attack Vector

Classification	Primary Vector	Requirement	Malware Example
Worm	Network Vulnerabilities	No User Action	WannaCry
Trojan	Social Engineering (Deception)	User Must Execute	Emotet
Virus	Infected Host Files	User Must Open File	Melissa
Drive-by	Browser Vulnerabilities	User Visits Website	Angler Exploit Kit
USB/Physical	Removable Media	User Plugs in Device	Stuxnet

Melissa

- Melissa (also known as "Mailissa," "Simpsons," or "Kwyjibo") is one of the most famous malware outbreaks in history.
- Released in March 1999, it is a classic example of a Macro Virus that utilized a hybrid attack vector.
- **Type:** Macro Virus / Mass-Mailing Worm
- **Attack Vector:** Social Engineering (Email) + File Infection (Microsoft Word Documents)

Melissa: The Attack Vector (How it got in)

- Melissa was unique because it combined a technical exploit with social manipulation.
 - **The Vehicle:**
 - An email with an attached Microsoft Word document (usually LIST.DOC).
 - **The Bait (Social Engineering):**
 - The subject line usually read: *"Important Message From [Sender Name]"*
 - **The Hook:**
 - The body of the email contained a sentence designed to make you curious, such as: *"Here is that document you asked for ... don't show anyone else ;-)"*

Melissa: The Mechanism

Melissa exploited the **VBA (Visual Basic for Applications)** macro language built into Microsoft Office.

- 1. Infection:** The user receives the email and opens the Word document.
- 2. Execution:** Microsoft Word would usually pop up a warning asking if the user wanted to "Enable Macros." Because the email came from a trusted friend or colleague, most users clicked "**Yes.**"
- 3. Propagation:** Once macros were enabled, the virus executed a script that hijacked Microsoft Outlook. It automatically sent a copy of itself to the **first 50 contacts** in the user's address book.
- 4. Payload:** While it didn't delete files (unless it was the specific date of the original payload trigger), it inserted quotes from the TV show *The Simpsons* into active documents.

Why It Was devastating

- Every infected person instantly emailed 50 other people, the traffic grew exponentially.
- This created an unintentional **Distributed Denial of Service (DDoS)** attack.
- Corporate and government email servers (including Microsoft and Intel) were overloaded by the tsunami of emails and had to be shut down to stop the spread.

Historical Significance

- **Impact:**

- It caused an estimated **\$80 million** in damages (mostly in cleanup and lost productivity).

- **The Fix:**

- It forced Microsoft to change the default settings in Word/Outlook to disable macros by default, a standard that exists to this day.

- **The Creator:**

- David L. Smith was caught, prosecuted, and sentenced to 20 months in federal prison.

WannaCry

- **WannaCry** (May 2017) is the definitive example of a **Network-Based** attack vector.
- It is historically significant because it demonstrated how a "weaponized" government exploit could be leaked and used to cause global chaos.

Classification

- **Type:**

- Ransomworm (Ransomware + Worm)

- **Attack Vector:**

- Network-Based / Software Vulnerability (Zero-Click)

The Attack Vector (How it got in)

- **The Vulnerability:**

- It targeted a flaw in the **SMBv1** (Server Message Block) protocol, which is used by Windows computers to share files and printers over a network.

- **The Weapon:**

- It used a specific exploit called **EternalBlue**.

- *Note:*

- EternalBlue was reportedly developed by the US National Security Agency (NSA) as a cyber-weapon.
- It was stolen and leaked by a hacker group called "The Shadow Brokers" a month before the attack.

The Mechanism

- **Scanning:**

- The malware automatically scanned the internet for computers with **Port 445** open (the port used for SMB).

- **Exploitation:**

- When it found a vulnerable computer, it fired the EternalBlue exploit.
- This tricked the computer into allowing the attacker to run code remotely.

- **Infection:**

- It installed a backdoor (DoublePulsar) and then the ransomware payload.

- **Encryption:**

- It encrypted the user's files (images, documents, etc.) and demanded \$300–\$600 in Bitcoin to unlock them.

- **Propagation:**

- Crucially, once inside one computer, it used the network to instantly attack every other unpatched computer in that same building/network.

Impact

- **Healthcare Impact:**

- It crippled the **NHS (National Health Service)** in the UK. Ambulances were diverted, and surgeries were cancelled because hospitals couldn't access patient records or X-rays.

- **Global Reach:**

- It infected over **200,000 computers** in 150 countries within days.

The "Kill Switch"

- **The Discovery:**

- A British security researcher named **Marcus Hutchins** (also known as *MalwareTech*) was analyzing the WannaCry code.

- **The Code:**

- He noticed the malware was constantly trying to connect to a weird, gibberish web domain (e.g., www.iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com).

- **The Logic:**

- The malware was programmed: "If this website is **live**, STOP spreading.
- If this website is **offline**, KEEP attacking."

- **The Fix:**

- Hutchins realized the hackers hadn't registered the website yet. So, he bought the domain for about **\$10**.

- **The Result:**

- As soon as the website went live, every copy of WannaCry around the world checked the site, saw it was active, and instantly shut itself down.
- Hutchins had accidentally triggered the hacker's Kill Switch.

Malware Analysis

- Malware analysis is the systematic study of malicious software and its behavior.
- Its primary objective is to understand how malware operates.
- It aims to determine how malware can be detected, contained, and eliminated.
- The process involves examining a suspected malicious binary file.
- Analysis is performed in a controlled and secure (sandboxed) environment.
- The goal is to identify the malware's characteristics, structure, and functionality.
- Findings are used to develop stronger security controls and defensive measures.
- This helps protect an organization's systems, data, and network from future attacks.

Malware Analysis

- The process of comprehending the behavior and inner workings of malware is known as Malware Analysis, a crucial aspect of cybersecurity that aids in understanding the threat posed by malicious software and devising effective countermeasures.

Malware Analysis

- In our pursuit of Malware Analysis, we delve into the malware's code, structure, and functionality to gain profound insights into its purpose, propagation methods, and potential impact on targeted systems.
- By answering pertinent questions, such as the type of malware (e.g., spybot, keylogger, ransomware), its intended behavior on endpoints, the aftermath of its execution (including generated artifacts on the network or endpoint and possible connections to Command and Control (C2) servers), the extent of damage it can inflict, its attribution to specific threat groups, and crafting detection rules based on the analysis to detect the malware across the entire network, we can devise robust defense mechanisms against these threats

Malware analysis- Purposes

- Detection and Classification:
 - ~ Through analyzing malware, we can identify and categorize different types of threats based on their unique characteristics, signatures, or patterns.
 - ~ This enables us to develop detection rules and empowers security professionals to gain a comprehensive understanding of the nature of the malware they encounter.

Malware analysis- Purposes

- Reverse Engineering:

- ~ Malware analysis often involves the intricate process of reverse engineering the malware's code to discern its underlying operations and employed techniques.
- ~ This can unveil concealed functionalities, encryption methods, details about the command-and-control infrastructure, and techniques used for obfuscation and evasion.

Malware analysis- Purposes

- Behavioral Analysis:

- ~ By meticulously studying the behavior of malware during execution, we gain insights into its actions, such as modifications to the file system, network communications, changes to the system registry, and attempts to exploit vulnerabilities.
- ~ This analysis provides invaluable information about the impact of the malware on infected systems and assists in devising potential countermeasures.

Malware analysis- Purposes

- Threat Intelligence:

- ~ Through malware analysis, threat researchers can amass critical intelligence about attackers, their tactics, techniques, and procedures (TTPs), and the malware's origins.
- ~ This valuable intelligence can be shared with the wider security community to enhance detection, prevention, and response capabilities.

Malware analysis- Purposes

Term	Meaning	What It Describes	Example
Tactics	The strategic goal of the attacker	<i>Why</i> the attacker is doing something	Gaining initial access, maintaining persistence, exfiltrating data
Techniques	The method used to achieve a tactic	<i>How</i> the attacker accomplishes the goal	Phishing emails, exploiting software vulnerabilities, credential dumping
Procedures	The specific implementation of a technique	<i>Exactly how</i> the technique is carried out	Sending a Word document with a malicious macro that downloads malware from a specific URL

Forensic Importance of Malware Analysis

- Malware analysis in collecting threat intelligence
- Malware analysis in incident response
- Malware analysis in threat hunting
- Malware analysis in creating detections

- **Malware analysis in collecting threat intelligence**

- Threat intelligence (also called cyber threat intelligence or CTI) is information used to identify and track cyber threats.
- It is usually shared in the form of Indicators of Compromise (IoCs).
- IoCs help security teams detect, prevent, and investigate cyberattacks.
- Threat intelligence also supports attribution, allowing analysts to link attacks to the same threat actor.

• Malware analysis in collecting threat intelligence

- Common IoCs include:
 - ~ File hashes (MD5, SHA-1, SHA-256)
 - ~ Network artifacts such as domains, IP addresses, and URLs
- IoCs are exchanged through threat-sharing platforms, security communities, and published reports.
- **Indicators of Attack (IoAs)** describe suspicious or malicious behavior rather than static artifacts.
- An example of an IoA is a DMZ system suddenly communicating with many internal hosts.
- IoAs reveal attacker intent and can be mapped directly to Tactics, Techniques, and Procedures (TTPs).
- Malware analysis produces more accurate and complete IoCs than methods such as log analysis or traditional forensics.
- Some IoCs discovered through malware analysis are difficult to identify using other investigation techniques.
- These IoCs may include specific web pages, social media accounts, or cloud services used by attackers.
- Tracking such IoCs helps security teams disrupt and dismantle malicious campaigns more quickly.

IoC vs IoA

Feature	IoC – Indicator of Compromise	IoA – Indicator of Attack
Meaning	Evidence that a system has already been compromised	Evidence that an attack is in progress or being attempted
Focus	Artifacts left behind by malware	Attacker behavior and intent
Answers	“What was used in the attack?”	“What is the attacker trying to do?”
Nature	Static	Behavioral and dynamic
Changes over time	Can become obsolete when attackers change tools	Remains relevant even if tools change
Detection type	Reactive	Proactive

Examples of IoC and IoA

- **IoCs (Indicators of Compromise):**

- ~ A malicious file hash (MD5, SHA-256)
- ~ A known malicious IP address or domain
- ~ A ransomware executable found on disk
- ~ A suspicious registry key created by malware

- These confirm that a system was infected or contacted a malicious source.

- **IoAs (Indicators of Attack):**

- ~ A user account attempting many failed logins (brute force)
- ~ A server in the DMZ connecting to multiple internal systems
- ~ A process injecting code into another process
- ~ A script attempting to disable security software

- These indicate attacker behavior, often before full compromise.

- **Malware analysis in collecting threat intelligence**

- Malware analysis also adds invaluable context as to what each IoC represents and what it means if it is detected within an organization.
- Understanding this context may help in prioritizing the corresponding events.

Malware analysis in incident response

- When an attack is detected, the organization initiates its incident response process.
- The first step is **containment** of infected systems to stop further spread.
- A forensic investigation is then conducted to determine the cause and impact of the attack.
- If malware is involved, the malware analysis process begins.
- Analysts **first identify** all Indicators of Compromise (IoCs).
- IoCs help locate other infected machines and related malicious files.
- Malware analysis determines the capabilities of the payload, such as:
 - Whether it can spread across the network
 - Whether it steals credentials or sensitive data
 - Whether it exploits unpatched vulnerabilities
- This information helps measure the true impact of the attack.
- It also supports the development of remediation and prevention strategies.
- Malware analysis can decrypt and interpret malicious network communications.
- Security tools such as Network Detection and Response (NDR) systems may provide traffic captures for this purpose.
- Analyzing this traffic helps identify attacker intent, compromised assets, and stolen data.
- Malware analysis is therefore a critical part of cyber-incident response.

Malware analysis in threat hunting

- Threat hunting differs from incident response by focusing on the active search for Indicators of Attack (IoAs).
- It can be proactive, occurring before an alert is triggered, or reactive, addressing a suspected threat.
- Understanding attacker tactics and techniques is essential for effective threat hunting.
- This knowledge gives analysts a high-level view of how attackers operate across the attack surface.
- The MITRE ATT&CK framework provides a structured model of real-world attacker behavior.
- Malware analysis strengthens threat hunting by deepening understanding of attacker methods.
- It helps analysts recognize how malware:
 - ~ Communicates with Command-and-Control (C2) servers
 - ~ Evades or bypasses security defenses
 - ~ Steals credentials and sensitive data
 - ~ Escalates privileges
- This insight allows hunters to know what to look for and where to look.
- Analysts can then search logs, memory, and disk artifacts for traces of these techniques.
- Malware analysis therefore makes threat hunting more accurate, efficient, and context-driven.

Malware analysis in creating detections

- Many companies worldwide develop and deploy cybersecurity solutions to protect against cyber threats.
- These systems detect malicious activity at different stages of an attack.
- Common detection methods include:
 - ~ Monitoring network traffic
 - ~ Analyzing system logs and registry entries
 - ~ Inspecting files statically and during execution
- Detection often relies on rules, signatures, and behavioral patterns.
- These rules are used to distinguish malicious activity from legitimate activity.
- Malware analysis is essential for identifying true malicious patterns.
- It helps security teams understand how malware actually behaves.
- This enables the creation of accurate and robust detection rules.
- Proper malware analysis reduces false positives while improving threat detection.

- **Threat intelligence** tells you what malware is out there and how it works.
- **Threat hunting** uses that knowledge to search for and eliminate malware inside your own systems.

Aspect	Threat Hunting	Threat Intelligence
Core purpose	Find active or hidden malware inside the organization	Understand what malware exists and how it operates in the wild
Main focus	Internal systems and infections	External malware campaigns and threat actors
Key question	“Is malware currently running or hiding in our environment?”	“What malware families, tools, and techniques are attackers using?”
Type of work	Hands-on investigation and detection	Research, collection, and analysis of malware information
Data used	Logs, memory, disk artifacts, EDR/NDR data, suspicious processes	Malware samples, IoCs, IoAs, TTPs, threat feeds
Typical output	List of infected machines, persistence mechanisms, and attacker activity	Malware reports, signatures, and lists of IoCs/IoAs
Role of malware analysis	Used to understand how detected malware behaves and how to find it	Used to classify malware, extract IoCs, and map it to known campaigns
Timing	During or after malware execution	Before, during, and after malware campaigns
Value to defense	Stops malware already inside the network	Prepares defenses against malware that may attack

Introduction to different analysis techniques

- **Static Analysis:**

- ~ involves scrutinizing the malware's code without executing it, examining the file structure, identifying strings, searching for known signatures, and studying metadata to gain preliminary insights into the malware's characteristics.

- **Dynamic Analysis:**

- ~ executing the malware within a controlled environment, such as a sandbox or virtual machine, to observe its behavior and capture its runtime activities.
- ~ Includes monitoring network traffic, system calls, file system modifications, and other interactions.

Introduction to different analysis techniques

- **Code Analysis:**

- ~ Code analysis (includes reverse engineering) and involves disassembling or decompiling the malware's code to understand its logic, functions, algorithms, and employed techniques.

- ~ This helps in identifying concealed functionalities, exploitation methods, encryption methods, details about the command-and-control infrastructure, and techniques used for obfuscation and evasion. Inferentially, code analysis can also help in uncovering potential Indicators of Compromise (IOCs).

- **Memory Analysis:**

- ~ Analyzing the malware's interactions with system memory helps in identifying injected code, hooks, or other runtime manipulations.

- ~ This can be instrumental in detecting rootkits, analyzing anti-analysis techniques, or identifying malicious payloads.

Introduction to different analysis techniques

- **Malware Unpacking:**

- ~ Process of extracting and isolating the hidden malicious code within a piece of malware that uses packing techniques to evade detection.
- ~ Packers are used by malware authors to compress, encrypt, or obfuscate their malicious code, making it harder for antivirus software and other security tools to identify the threat.
- ~ Unpacking involves reverse-engineering these packing techniques to reveal the original, unobfuscated code for further analysis.
- ~ This can allow researchers to understand the malware's functionality, behavior, and potential impact.

Malware Behavior

- Malware behavior refers to the actions and techniques a malicious program performs once it reaches a target system.
- Understanding malware behavior is central to malware analysis, digital forensics, and threat detection because it reveals both the **intent** of the attacker and the **impact** on the system.

1. Initial Execution and Installation

- After being delivered through phishing, exploits, or removable media, malware typically:
 - ~ Executes its payload
 - ~ Drops additional files
 - ~ Modifies system settings to remain active
- It may run directly from memory or disguise itself as a legitimate application.

2. Persistence

- To survive reboots and remain undetected, malware often:
 - ~ Creates registry run keys or startup entries
 - ~ Installs scheduled tasks or services
 - ~ Modifies system files or boot records
- Persistence ensures the attacker retains long-term access.

3. Privilege Escalation

- Many malware families attempt to:
 - ~ Exploit operating system vulnerabilities
 - ~ Abuse misconfigured permissions
 - ~ Steal administrator credentials
- This allows full control over the system.

4. Defense Evasion

- Malware tries to avoid detection by:
 - ~ Disabling antivirus or firewalls
 - ~ Using encryption and packing
 - ~ Running only in memory
 - ~ Detecting virtual machines or sandboxes
- These techniques reduce the chance of being analyzed or blocked.

5. Command and Control (C2) Communication

- Most modern malware communicates with an external server to:
 - ~ Receive commands
 - ~ Download additional payloads
 - ~ Upload stolen data
- This communication is often encrypted or disguised as normal web traffic.

6. Lateral Movement

- To spread within a network, malware may:
 - ~ Use stolen credentials
 - ~ Exploit network vulnerabilities
 - ~ Copy itself to shared drives or remote systems
- This expands the attack beyond one machine.

7. Data Collection and Exfiltration

- Malware commonly targets:
 - ~ Login credentials
 - ~ Financial information
 - ~ Personal or corporate data
 - ~ Intellectual property
- The stolen data is then sent to the attacker's servers.

8. Impact and Damage

- Depending on its purpose, malware may:
 - ~ Encrypt files (ransomware)
 - ~ Destroy or alter data
 - ~ Spy on users
 - ~ Hijack computing resources

MITRE ATT&CK framework

- Globally recognized knowledge base that maps how real-world malware and attackers behave across the entire lifecycle of a cyberattack.
- It translates raw malware behavior into structured tactics and techniques that security teams can detect, investigate, and defend against.

How MITRE ATT&CK Represents Malware Behavior

- When malware runs, every action it performs can be mapped to an ATT&CK tactic and technique.
- This allows analysts to understand not just what the malware did, but why it did it.
- ATT&CK organizes behavior into
 - ~ tactics (the attacker's goal) and
 - ~ techniques (how that goal is achieved).

Malware Behavior Mapped to MITRE ATT&CK

Malware Behavior	ATT&CK Tactic	ATT&CK Technique (Example)
Arrives via phishing attachment	Initial Access	Phishing (T1566)
Runs malicious code	Execution	Command and Scripting Interpreter (T1059)
Creates startup registry key	Persistence	Boot or Logon Autostart Execution (T1547)
Exploits OS vulnerability	Privilege Escalation	Exploitation for Privilege Escalation (T1068)
Disables antivirus	Defense Evasion	Impair Defenses (T1562)
Steals passwords	Credential Access	Credential Dumping (T1003)
Connects to C2 server	Command and Control	Application Layer Protocol (T1071)
Moves to other systems	Lateral Movement	Remote Services (T1021)
Uploads stolen data	Exfiltration	Exfiltration Over C2 Channel (T1041)
Encrypts files	Impact	Data Encrypted for Impact (T1486)

Why MITRE ATT&CK Matters for Malware Analysis

- Describe malware behavior in a standardized language
- Compare different malware families
- Identify gaps in detection
- Build detection rules based on techniques instead of just file signatures